

SOC 통합 보안 대시보드 요구사항 정의서

Security Requirements Specification (SRS)

문서 버전 : v1.0

작성일 : 2026-06-09

대상 시스템 : Splunk Enterprise 10.4.0 기반 SOC 통합 보안 모니터링 대시보드

분류 : 내부용 / 보안 인프라 구축

구성 : WAF(ModSecurity) · IDS(Security Onion/Suricata·OSSEC) · pfSense(Snort·방화벽)

목차

1. 1. 개요 (목적·범위·배경·용어)
2. 2. 시스템 개요 (구성·데이터소스·토폴로지·플랫폼)
3. 3. 기능 요구사항 (FR-01 ~ FR-18)
4. 4. 비기능 요구사항 (NFR)
5. 5. 데이터 요구사항 (인덱스·정규화 스키마·룰 매핑)
6. 6. 화면·인터페이스 요구사항 (UI/UX)
7. 7. 탐지 커버리지 매트릭스
8. 8. 제약사항 및 가정
9. 9. 향후 개선 과제 (미해결)
10. 부록 A. 정규화 매크로(soc_base) 처리 흐름
11. 부록 B. 패널별 쿼리 카탈로그
12. 부록 C. 우선순위·상태 표기 범례

1. 개요

1.1 목적

본 문서는 다종(多種) 보안 장비에서 발생하는 로그를 단일 화면에서 통합 모니터링하기 위한 **SOC 통합 보안 대시보드**의 요구사항을 정의한다. 보안 관제 인력이 WAF·IDS·방화벽의 탐지 결과를 **장비별·공격유형별·위험도별**로 일관되게 조회하고, 실시간으로 공격을 인지·대응할 수 있도록 하는 것을 목적으로 한다.

1.2 범위

- **포함**: 로그 수집·정규화, 공격 유형 분류, 위험도 산정, 통합 대시보드 화면(탭/패널), 실시간 자동 갱신, 원본 로그 드릴다운, 노이즈/내부자산 필터링.
- **제외**: 자동 차단(IPS 능동대응), SOAR 연동 자동화 플레이북, 외부 위협 인텔리전스(TI) 연동, 로그 장기 보관 정책 — (향후 확장 과제로 9장 참조).

1.3 배경

WAF(ModSecurity), 네트워크 IDS(Security Onion의 Suricata + 호스트 OSSEC), 경계 방화벽(pfSense의 Snort 패키지 및 filterlog)이 각각 독립된 형식의 로그를 생성한다. 관제자가 장비별 콘솔을 개별 확인하면 동일 공격을 분산해서 보게 되어 대응이 지연된다. 이를 해결하기 위해 Splunk에 로그를 집계하고, **단일 정규화 스키마**로 통합하여 하나의 대시보드에서 교차 분석한다.

1.4 용어 및 약어

용어	설명
WAF	Web Application Firewall. 본 시스템은 Apache + ModSecurity(감사로그 <code>modsec:audit:serial</code>) 사용
IDS	Intrusion Detection System. Security Onion의 Suricata(NIDS) 및 OSSEC(HIDS), Sguil 경보 경유
Snort / Suricata	시그니처 기반 침입탐지 엔진. pfSense에는 Snort 패키지, Security Onion에는 Suricata 탑재
pfSense	경계(게이트웨이) 방화벽. filterlog(차단/허용) 및 Snort 경보 생성
soc_base	4종 로그를 단일 스키마로 통합·정규화하는 Splunk 검색 매크로 (본 시스템의 핵심)
severity	이벤트 위험도. 3=HIGH, 2=MEDIUM, 1=LOW
signature	정규화된 공격 시그니처명(예: SQL Injection, XSS, Port Scan)
source_type	탐지 장비 구분: <code>WAF Web</code> · <code>IDS/OSSEC</code> · <code>pfSense</code>
드릴다운	대시보드 행 클릭 시 원본(raw) 로그로 이동하는 기능

2. 시스템 개요

2.1 논리 구성



2.2 데이터 소스 (4종)

소스	수집 경로	탐지 방식 / 산출
WAF (ModSecurity)	index= waf_audit sourcetype= modsec:audit:serial	요청/응답 감사로그. attack-* 태그 카운트로 공격 유형 결정 → SQL Injection, XSS, RCE, Path Traversal/LFI, PHP Injection, WAF Anomaly
IDS (SO Suricata/OSSEC)	index= main sourcetype= syslog (sguild_alert)	Sguil DB(MySQL) → 폴링 포워드 → "Alert Received" 형식. alert_msg 정규식으로 분류 → SQL Injection(IDS), XSS(IDS), Path Traversal/LFI(IDS), Port Scan(IDS), OSSEC 호스트 이벤트트 등
pfSense Snort	index= pfsense syslog snort[pid]:	경계 NIDS. [gid:sid:rev] msg [Classification] [Priority]{PROTO} src:port->dst:port 파싱 → SQLi/XSS/File/PortScan/HTTP Anomaly(Snort)
pfSense 방화벽	index= pfsense host=10.0.200.1 filterlog	행위(볼륨) 기반: 1분당 목적지 포트 ≥10 → Port Scan, 패킷 ≥500 → DDoS

2.3 네트워크 토폴로지

자산	IP	구간/역할
공격자(모의)	10.44.44.44 / .88	공격 대역 10.44.44.0/24
경계 NAT 주소	10.0.0.254	외부 노출 주소 (포트스캔/DDoS 1차 도달점)
pfSense 방화벽	10.0.200.1 / 10.0.100.1	게이트웨이(Snort+filterlog)
WAF	10.0.10.2	DMZ, ModSecurity
WAS	10.0.10.100	DMZ 웹 애플리케이션 서버

Security Onion	10.0.200.200	Suricata(NIDS)·OSSEC(HIDS)·Sguil
Oracle DB	10.0.200.100	intra 데이터베이스
Splunk	10.0.200.201	로그 집계·대시보드 (웹 8000 / REST 8089)

2.4 플랫폼

- Splunk Enterprise **10.4.0** (단일 인스턴스, search+index)
- 대시보드 형식: **Simple XML (form, theme=dark)**, 보조 스크립트 `soc_tabs.js`
- 핵심 지식객체: 검색 매크로 `soc_base` (app=search)

3. 기능 요구사항

우선순위: 필수 권장 선택 | 상태: 구현완료 예정

3.1 로그 수집 · 정규화

ID	요구사항	상세	우선	상태
FR-01	다중 로그 통합 수집	WAF·IDS·pfSense Snort·pfSense 방화벽 4종 로그를 Splunk 인덱스로 수집한다.	필수	완료
FR-02	단일 스키마 정규화	매크로 <code>soc_base</code> 가 4종 로그를 공통 필드(<code>source_type</code> , <code>signature</code> , <code>severity</code> , <code>src_ip</code> , <code>dest_ip</code> , <code>dest_port</code> , <code>uri</code> , <code>status</code> , <code>http_method</code>)로 정규화·통합한다.	필수	완료
FR-03	방향 보정	응답측 시그니처(예: ET ATTACK_RESPONSE)는 출발지/목적지를 교정하여 공격자가 출발지(src)가 되도록 한다.	권장	완료
FR-04	내부자산·노이즈 제외	내부망(10.0.0.0/16, 192.168/16, 172.16/12, 127/8)을 출발지로 하는 이벤트는 공격자 집계에서 제외(공격 대역 10.44.44.0/24·외부는 유지). Suricata 디코더 오탐(<code>protocol-command-decode</code> : 체크섬/조각화)은 제외.	필수	완료

3.2 공격 분류 · 위험도

ID	요구사항	상세	우선	상태
FR-05	공격 유형 분류	표준 공격 유형 5종으로 분류: SQL Injection · XSS · 파일 업/다운로드 · DDoS · Port Scan . (CSRF는 XSS로 통합)	필수	완료
FR-06	위험도 산정 정책	5종 공격 유형은 소스·우선순위와 무관하게 HIGH(3) 로 통일. 그 외(OSSEC 호스트 이벤트, 정책/이상 징후 등)는 원 severity 유지(MEDIUM/LOW).	필수	완료
FR-07	룰/시그니처 식별	원본 룰 식별자(ModSecurity CRS rule id, Snort/Suricata SID)는 로그에 보존되어 조회 가능해야 한다.	권장	부분

3.3 화면 구성 · 탐색

ID	요구사항	상세	우선	상태
FR-08	장비별 탭	상위 탭으로 장비 선택: WAF/Web · pfSense · IDS(Squid) · 전체 로그 · 웹로그(전체) .	필수	완료
FR-09	공격유형 하위 탭	장비 선택 시 하위 탭으로 공격유형 선택: SQLi · XSS · DDoS · 파일 · Port Scan .	필수	완료
FR-10	통합(전체 로그) 뷰	전 장비·전 공격을 한 화면에서 보는 통합 SOC 뷰. 접속/새로고침 시 기본 진입 화면 .	필수	완료
FR-11	웹로그 원본 뷰	위험 분류 없이 WAF 접근로그(<code>index=web</code>) 전체 요청을 조회.	권장	완료
FR-12	기간·위험도 필터	분석 기간(15분/1시간/4시간/24시간/7일) 및 위험도 필터(전체/HIGH만/MEDIUM 이상) 제공.	필수	완료

3.4 분석 패널

ID	요구사항	상세	우선	상태
FR-13	실시간 상태·KPI	장비별 마지막 수신 경과(분), 최근 5분 HIGH/MEDIUM/TOTAL, 전체 이벤트·고위험·고유 출발지·IDS 경보 KPI.	필수	완료
FR-14	HIGH 경보 목록	severity=3 경보 최근 20건을 경과시간·위험도색과 함께 제시 (즉시 대응용).	필수	완료
FR-15	반복 공격자 분석	출발지 IP별 최초/최근 발생, 이벤트 수, 공격 유형, 대상 IP 집계(Top 10).	권장	완료
FR-16	추이·분포·Top N	시간대별 추이(소스별), 위험도 분포(파이), 탐지 소스별 분포, 공격유형 Top 10(이벤트 severity≥MEDIUM 기준), 공격 대상 서버.	권장	완료
FR-17	상세 로그 + 포트	이벤트 상세 표에 시간·소스·시그니처·위험도·출발/목적지 IP·목적지 포트·URI·상태코드 표시.	필수	완료
FR-18	원본 로그 드릴다운	로그 행 클릭 시 새 탭에서 해당 출발지 IP의 원본(raw) 로그를 분석 기간 범위로 조회.	권장	완료
FR-19	실시간 자동 갱신	통합 뷰는 수동 새로고침 없이 30초 주기로 자동 갱신되어야 한다.	필수	완료

4. 비기능 요구사항

ID	항목	요구사항
NFR-01	성능	패널마다 무거운 매크로를 중복 실행하지 않도록 공용 베이스 검색(soc_base 1회 실행) + 패널 post-process 구조를 적용한다. 통합 뷰 갱신 1회당 soc_base 실행은 최소화한다(12회→1회).
NFR-02	실시간성	자동 갱신 주기 30초(조정 가능 10~60초). 동시검색 한도(기본 10) 내에서 안정 동작.
NFR-03	정확성(오탐 제어)	정상 통신 오탐(예: WAS→DB Oracle 포트 연결, 서버 yum/apt 업데이트, 체크섬 오프로딩)은 공격으로 집계하지 않는다.
NFR-04	가독성(사용성)	40~50대 관제자 고려: 큰 글자, 넓은 클릭 영역, 위험도 색상 코드. 패널 제목은 명확한 진한 색. 행 hover/선택 시 글자가 가려지지 않아야 한다.
NFR-05	일관성	위험도 색상은 전 패널 공통: HIGH=빨강(#dc4e41) · MEDIUM=노랑(#f8be34) · LOW=초록(#53a051) .
NFR-06	확장성	신규 장비/공격 유형 추가 시 soc_base 분기 추가만으로 전 패널에 반영되어야 한다(패널 개별 수정 최소화).
NFR-07	유지보수성	분류 임계치·정규식·필터는 매크로/토큰 한 곳에서 관리. SPL 주석(/* */) 미사용(매크로 확장 오류 방지).
NFR-08	보안(접근통제)	대시보드/REST 접근은 인증(admin 등 권한 계정) 필요. 관리 포트(8089) 노출 최소화.

5. 데이터 요구사항

5.1 인덱스

인덱스	주 sourcetype	내용
waf_audit	modsec:audit:serial	ModSecurity 감사로그(WAF 공격)
web	waf_web	WAF/웹 접근로그(Apache combined)
pfsense	syslog (filterlog, snort)	pfSense 방화벽 차단/허용 + Snort 경고
main	syslog(sguil_alert), snort:alert, ossec_alert, bro	Security Onion(Suricata·OSSEC·Zeek) 경고·메타데이터

5.2 정규화 스키마 (soc_base 출력 공통 필드)

필드	타입/값	의미
source_type	WAF Web · IDS/OSSEC · pfSense	탐지 장비
signature	문자열	정규화 공격 시그니처(예: SQL Injection, XSS, Port Scan)
severity	3 / 2 / 1	위험도 HIGH / MEDIUM / LOW
src_ip / dest_ip	IPv4	출발지(공격자) / 목적지(대상)
dest_port	정수	목적지 포트(웹=80/443, 스캔=대상 포트; 호스트 이벤트는 없음)
uri / status / http_method	문자열/정수	웹 요청 컨텍스트

5.3 공격 유형 ↔ 시그니처 분류 규칙

공격 유형	분류 정규식(signature 매칭)	위험도
SQL Injection	(?i)sql	HIGH
XSS (CSRF 포함)	(?i)xss cross.?site script csrf	HIGH
파일 업/다운로드	(?i)upload download webshell traversal lfi rfi passwd etc/	HIGH
DDoS	(?i)ddos flood denial	HIGH
Port Scan	(?i)scan recon nmap sweep	HIGH

※ 위험도 기준 명확화 — "공격 유형 Top 10 (Severity ≥ MEDIUM)" 등에서의 위험도는 각 로그 이벤트 자체의 severity(HIGH/MEDIUM/LOW)를 의미하며, 화면 상단의 "위험도 필터" 드롭다운과는 별개이다.

6. 화면 · 인터페이스 요구사항

6.1 탭 · 상태 모델

입력	토큰	동작
장비 탭(dev)	mode_dev / mode_all / mode_weblog, dev_filter	장비 선택 → 해당 source_type 필터 + 모드 전환
공격유형 탭(atk)	atk_filter	signature 정규식 필터 설정
분석 기간	earliest_tok	-15m / -1h / -4h / -24h(기본) / -7d
위험도 필터	sev_filter	전체 / severity=3 / severity≥2 (보안 이벤트 목록 표에 적용)

상위 배너 탭은 `soc_tabs.js` 가 스타일 탭 클릭을 네이티브 입력에 연결하여 토큰을 전환한다. 장비 전환 시 첫 공격 하위탭이 자동 선택된다.

6.2 화면 가독성 규칙

- 위험도 색상: **HIGH 빨강** / **MEDIUM 노랑** / **LOW 초록** (Severity 컬럼 기준).
- 상태코드 색상: 2xx 초록, 3xx 파랑, 4xx 노랑, 5xx 빨강.
- 패널 제목: 진한색(검정) + 굵게. 버튼 hover/선택 및 표 행 hover/선택 시 충분한 명도 대비 유지(글자 가림 금지).
- 단일값(KPI)은 큰 글자 + 블록 색상으로 임계 초과 시 적색 강조.

6.3 드릴다운 · 자동 갱신

- 로그 표의 행 클릭 → 새 탭에서 `index=* "<출발지 IP>"` 원본 로그를 분석 기간으로 조회(웹로그는 `index=web` 한정).
- 통합 뷰는 공용 베이스 검색의 `<refresh>30s</refresh>` 로 30초마다 전 패널 자동 갱신.

7. 탐지 커버리지 매트릭스

각 탐지 소스는 관측 구간이 달라 상호 보완한다. 동일 공격이 여러 소스에서 잡히면 통합 뷰에서 함께 표시된다.

공격 유형	WAF (DMZ 앱계층)	IDS/SO (DMZ·내부)	pfSense (경계/GW)
SQL Injection	◎ 탐지	◎ 탐지	◎ 탐지(Snort)
XSS	◎ 탐지	△ (룰 의존)	◎ 탐지(Snort)
파일 업/다운로드·LFI	◎ 탐지	○ /etc/passwd 등	◎ 탐지(Snort)
Port Scan	△	○ DMZ 대상 시	◎ 경계 스캔(Snort+filterlog)
DDoS(불륨)	×	× (시그니처 IDS는 미탐)	◎ filterlog 행위탐지

◎ 주 탐지 · ○ 부분 · △ 제한적 · × 미탐

SO Suricata는 경계(WAN, 10.0.0.x) 미관측 → 경계로 들어오는 포트스캔·DDoS는 **pfSense**가 담당. SO는 DMZ/내부의 웹 공격을 담당.

8. 제약사항 및 가정

- **플랫폼 의존:** Splunk 10.4.0 Simple XML 기반. 표 셀 색상은 셀 자기 값으로만 결정 가능(타 컬럼 값 기준 색칠 불가) → 위험도색은 Severity 전용 컬럼으로 표기.
- **시간대:** Security Onion은 UTC, Splunk 서버는 KST(+09:00). 대시보드는 KST로 정상 표기되므로 시간 검증은 Splunk 기준으로 한다.
- **탐지 위치 한계:** SO 센서는 DMZ·내부 미러링만 수행, 경계(WAN) 트래픽 미관측. 경계 공격 탐지는 pfSense에 의존.
- **내부 발신 공격:** 내부망 출발지(10.0.0.0/16 등) 이벤트는 공격자 집계에서 제외하므로, 내부 측면이동(lateral)은 본 정책상 탐지 대상에서 제외(현 랩 환경 기준 정상 트래픽 노이즈 제거 목적).
- **가정:** 각 장비의 로그 전송 경로(syslog/UF/DB 폴링 포워더)가 정상 동작함을 전제. 단일 경로 장애 시 해당 소스 공백 발생.

9. 향후 개선 과제 (미해결)

ID	과제	내용	우선
EN-01	장비/웹로그 탭 자동 갱신	현재 자동 갱신은 통합(전체로그) 뷰에 적용. 장비별·웹로그 탭도 베이스 검색 방식으로 확장.	권장
EN-02	"전체/기타" 하위탭	5종 외 이벤트(OSSEC 호스트, ET POLICY, Suricata 이상 등)를 장비 탭에서 볼 수 있는 보조 탭 추가.	선택
EN-03	룰 ID 컬럼화(FR-07)	ModSecurity CRS id, Snort/Suricata SID를 상세 표 컬럼으로 노출.	권장
EN-04	HIGH 경보 자동 통지	HIGH severity 발생 시 이메일/웹훅 자동 알림(현재 조회형, 알림 미구성).	권장
EN-05	경계 IDS 가시성	SO 센서가 경계(WAN) 구간도 미러링하도록 span 확장(선택).	선택
EN-06	테스트 이벤트 정리	파이프라인 점검용 TEST 이벤트가 HIGH로 집계되는 잡음 제거.	선택

부록 A. 정규화 매크로(soc_base) 처리 흐름

```
(1) WAF : index=* sourcetype="modsec:audit:serial"
        → A/B섹션 rex(IP·포트·URI·status) + attack-* 태그 카운트 → signature/severity
(2) append IDS : index=* sourcetype=syslog sguild_alert
        → "Alert Received" 파싱 + alert_msg 분류, ATTACK_RESPONSE 방향 swap,
        디코더 오탐(protocol-command-dec) 제외
(3) append pfSense Snort : index=pfsense snort[pid]:
        → [gid:sid:rev] msg [Class][Priority]{PROTO} src:port->dst:port 파싱
(4) append pfSense 방화벽 : index=pfsense host=10.0.200.1 filterlog
        → 1분 bin 집계, 포트수>=10=Port Scan / 패킷>=500=DDoS
(공통 후처리)
| ET WEB_SERVER 방향 보정
| 내부망 CIDR 제외 (10.0.0.0/16,192.168.16,172.16/12,127/8 / 공격대역 10.44.44.0/24 유지)
| 5종 공격유형 severity=HIGH 통일
```

부록 B. 패널별 대표 쿼리 (통합 뷰)

패널	post-process 쿼리(베이스=soc_base)
전체 이벤트	stats count
고위험 이벤트	where severity=3 stats count
고유 출발지 IP	where src_ip!="0.0.0.0" stats dc(src_ip)
HIGH 경보 목록	where severity=3 sort -_time head 20 table ..., dest_port, ...
반복 공격자 분석	where src_ip!="0.0.0.0" stats count, earliest(_time), latest(_time) ... by src_ip head 10
공격 유형 Top 10	where severity>=2 stats count by signature sort -count head 10
시간대별 추이	timechart count by source_type
위험도 분포	eval sev_label=case(...) stats count by sev_label
보안 이벤트 목록	\$sev_filter\$ sort -_time head 50 table ..., dest_port, ...

부록 C. 표기 범례

필수 반드시 충족 **권장** 충족 권장 **선택** 선택 사항 | **완료** 구현 완료 **부분/예정**